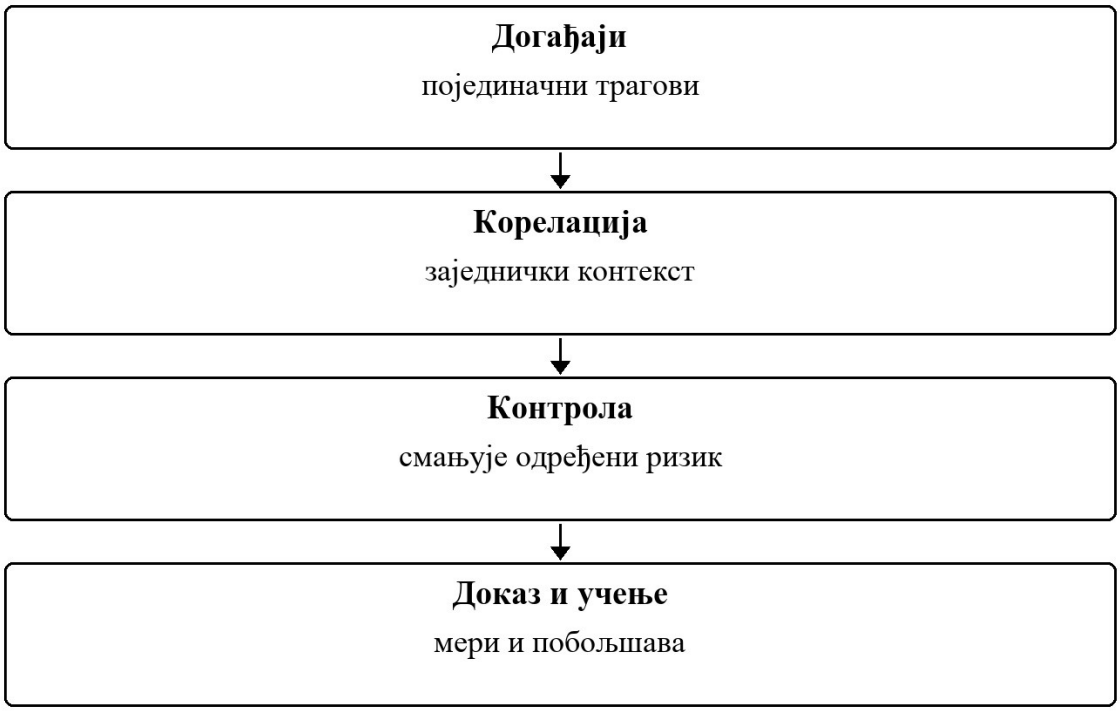
Корелација догађаја, ефективност контрола и учење

Основе информационе безбедности · 08

Завршна слика безбедности не састоји се од појединачних контрола, већ од њихове везе. Догађаји добијају смисао када се корелишу, контрола добија вредност када постоји свеж доказ да ради, а инцидент постаје прилика да се систем побољша без прикривања грешака.

Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.



Слика 1. Безбедност као процес који се мери и унапређује

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

8.1 Контрола има смисао тек уз доказ

Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.

- Корелација повезује догађаје кроз време, актере и ресурсе, а не само по једној поруци лога.
- Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.
- Пост-инцидент преглед испитује систем и процес, не тражи најближег кривца.

Питање за дискусију

Изаберите једну контролу и покажите који ризик ублажава, који доказ чува и како бисте приметили да је престала да ради.

8.2 Како се ова тема види у развоју

Добра безбедносна анализа показује узрочну везу: коју имовину штитимо, који сценарио разматрамо, која контрола делује и како знамо да њено понашање још увек одговара намери. Кратак, јасан доказ вреди више од дуге листе функционалности.

Честе грешке које треба препознати

- Закључивање из једног догађаја без ширег контекста.
- Аутоматска акција са великом последицом без заштитне провере.
- Оцена контроле само по томе да ли је имплементирана.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

8.3 Пример: контрола постоји, али нема свеж доказ

Систем има правило које ограничава приступ осетљивом ресурсу. Правило је било успешно тестирано пре неколико месеци, али се у међувремену променио модел улога и додат је нови улаз у систем. Без новог доказа тим зна да контрола постоји, али не зна да ли још покрива стварни ризик. Ефективност зато укључује свежину, опсег и резултат провере.

- Корелација повезује низ догађаја у јединствен приказ понашања система.
- Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.
- Аутоматизован одговор може убрзати реакцију, али радња са великом последицом захтева људску потврду и ревизијски траг.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

8.4 Дизајнерска одлука: корелација пре закључка

Појединачан догађај често има више могућих објашњења. Корелација повезује време, актера, ресурс и ток рада, па тим може да разликује случајну грешку од обрасца који заслужује реакцију. Циљ није прикупити највише података, већ повезати оне податке који мењају одлуку.

- Корелациони идентификатор повезује намеру, обраду и исход једне радње.
- Правила корелације морају бити објашњива, посебно када утичу на приоритет упозорења.
- Аутоматизација предлаже или ограничава одговор када је последица грешке велика.

8.5 Ефективност је више од постојања контроле

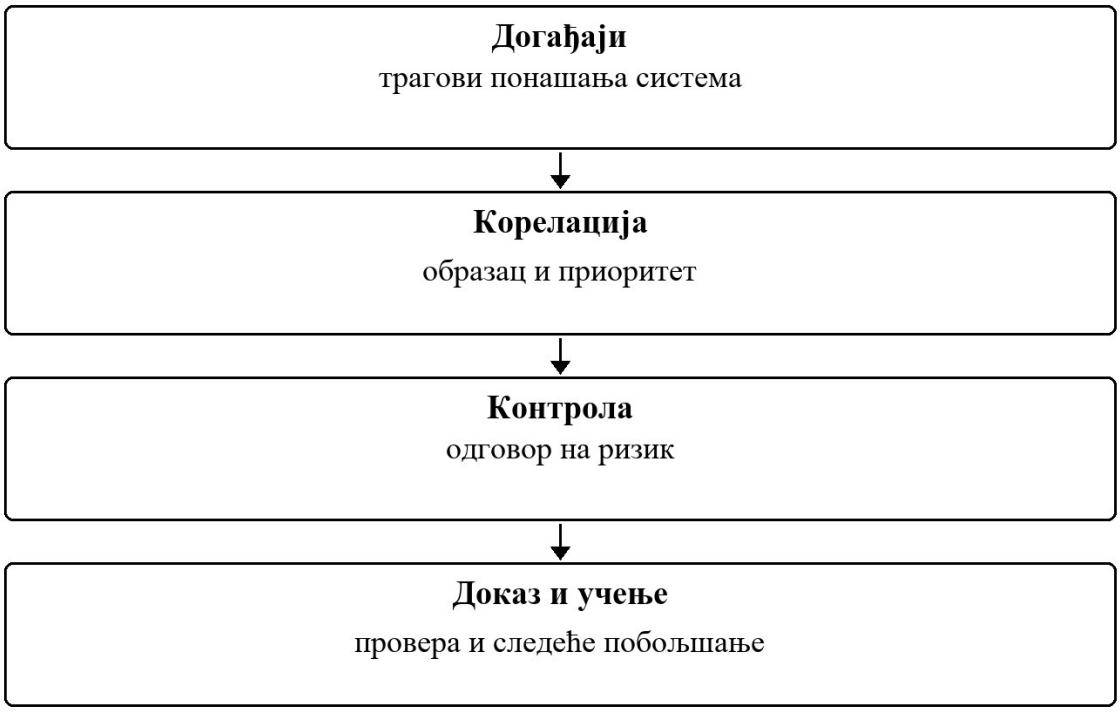
Контрола може бити имплементирана, али погрешно подешена, заобиђена новим током или застарела после промене система. Зато се њена ефективност процењује кроз доказ: последњи успешан тест, покривени сценарио, власника и способност да се проблем примети ако контрола закаже.

- Доказ се освежава када се промени релевантан ток, улога или граница поверења.
- Мера ефективности не скрива непознато, већ показује где доказа нема довољно.
- Квалитетна анализа повезује ризик, контролу, тест и преостало ограничење у једну јасну причу.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

8.6 Шема континуираног унапређивања безбедности



Слика 2. Шема континуираног унапређивања безбедности

Безбедност напредује кроз повратну спрегу: доказ мења разумевање ризика, а то мења контролу.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

8.7 Доказ, покривеност и ефективност

Табела 1. Питање и Слаб одговор

Питање	Слаб одговор	Поуздан одговор
Да ли контрола постоји?	Класа или подешавање је присутно.	Контрола има власника, активну конфигурацију и сврху.
Да ли ради?	Једном је ручно проверена.	Постоји поновљив тест или актуелан оперативни доказ.
Шта покрива?	Претпоставља се да важи свуда.	Познати су сценарио, граница и изузеци.
Како знамо да је ослабила?	Проблем се види тек после инцидента.	Метрика, упозорење или редован преглед откривају одступање.

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

8.8 Безбедносна повратна спрега

Зрео систем не завршава безбедност имплементацијом контроле. Догађаји и тестови стварају доказ, доказ мења процену ризика, а процена ризика води ка бољој политици или другачијој контроли. Тако се избегава лажни осећај да је једном завршени посао заувек довољан.

1. Догађај или тест открива образац који захтева пажњу.

2. Корелација повезује образац са имовином, актером и контролом.

3. Тим проверава да ли постојећа контрола покрива стварни сценарио.

4. Нова одлука ствара ажурирану политику, тест или оперативну процедуру.

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Корелација догађаја, ефективност контрола и учење". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

8.9 Извршиви пример

`EventCorrelator` повезује догађаје у случајеве. `ControlEffectivenessCalculator` пореди удео блокираних покушаја са задатим циљем; без покушаја нема основа за оцену ефективности.

Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.

```
cd examples/oib-dotnet/vezba-08-korelacija-efektivnost
dotnet run --project src/Oib.Vezba08.ConsoleUi
dotnet test Oib.Vezba08.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Контрола постоји, али не блокира потребан удео ризичних покушаја.
Тестови	`EventCorrelatorTests`, `ControlEffectivenessCalculatorTests`, `AnalyzeSecurityEventsHandlerTests`
Доказ	`SecurityAnalysisReport` приказује повезане случајеве и резултате мерења.

Задатак уз пример

Додати време догађаја и мерити колико је прошло од првог до последњег догађаја у случају. Проширити `CorrelationCase` и написати тест за случај са једним догађајем.

Контролна тачка КТ2 Завршна демонстрација и провера безбедносног квалитета

Друга контролна тачка одржава се у термину 8. вежбе. Тим демонстрира све обавезне случајеве употребе свих додељених целина у одобреном обиму, њихово повезивање, безбедносне одлуке и поновљиво покретање, уз ажурну документацију.

Обавезно за све тимове

1. Сви обавезни случајеви употребе AKTIVNOG/ODOBRENOG обухвата целина; ако се пуни нормативни обухват из СКУТУМ спецификације смањује, НАСТАВНИ ТИМ мора то унапред експлицитно објавити као ревизију.
2. Енд-то-енд демо: почетно стање → акција → одлука dozvoli/odbij → релевантан security/audit траг → коначан статус.
3. Унит + негативни сецурити + одговарајући integracioni/contract тестови по релевантној целини, Континуирана интеграција греен, документоване ревизије ПР.
4. Цлеан цлоне, миграције и seed/demo подаци раде према РЕАДМЕ-у.
5. API/event/policy уговори, тхреат модел, Записи о архитектонским одлукама, евиденција тестирања, индивидуални доприноси и ресидуал риск су ажурни.
6. Међутимски интеграција са реалним адаптером где је доступна; само заменска компонента не приказивати као завршену реалну интеграцију.

Додатно за тимове са 3 целине

- Трећа целина мора имати јавно одобрен опсег и извршив безбедносни ток са аутоматизованим тестовима; комплетан нормативни обим је обавезан осим ако је наставни тим формално променио спецификацију.

Приказ

Повезани енд-то-енд сценарио, позитиван и негативан тест, уговори и индивидуално образложење рада. Контролне тачке и термини одбране пројекта су одвојене обавезе.

Термин и обухват

Вежба 5–8 · Вежба 8 Исти захтеви приказани су на картици „Контролне тачке“.